加雲聯網股份有限公司

Security Vendor Management Plan

版 別：1.0

制訂日期：2024 年 12 月 04 日

修訂日期：2024 年 12 月 04 日

制修部門：XXX

頁 數：X

核准	審查	制定

文件發行/修訂記錄

版次	發行日期	生效日期	制修內容摘要
1.0			

Content

1.0 Purpose 4
1.1 Introduction 4
1.2 Purposes and Objectives 4
2.0 Scope 4
3.0 Definitions 5
3.1 Definitions 5
3.2 Abbreviations 5
3.3 Applicable Documents 6
3.3.1 Employer’s Requirements 6
3.3.2 Related Documents 6
4.0 Project Assets and SuC Description 7
5.0 Governance/Strategy 8
5.1 Main Contractor responsibilities 8
5.2 Vendors responsibilities 9
5.3 Asset responsibilities 13
6.0 Communicate Requirements to Vendor 14
6.1 Vendor selection process 14
6.2 Engineering plan 14
7.0 Vendor Management after Purchase Order 15
7.1 Progress Follow-up 15
7.2 Vendor Tests Management 15
7.2.1 Inspection and Test Protocol (ITP) 15
7.2.2 FAT 15
7.2.3 SAT 16
8.0 Appendix Template of Security Background Document 17

1.0 Purpose

1.1 Introduction

This document describes the OT Security management of the vendors in this project. This document also describes document delivery management for assets and SuC, OT Security documentation, policies and Procedures, OT Security Governance, Timeline, and Testing with the vendors.

1.2 Purposes and Objectives

Vendor management refers to the process of supervising, regulating, and enhancing an organization's interactions with its suppliers and service providers. It encompasses a strategic approach to selecting, managing, evaluating, and sustaining vendor relationships to achieve optimal performance, cost-effectiveness, and risk reduction.

The main objectives of vendor management are to increase efficiency, reduce expenses, and ensure the quality of the products and services delivered by vendors.

2.0 Scope

The System under Consideration (SuC) for IEC 62443-2-4 Dummy System, the applicable scope of systems, sub-components for OT Security Management Plan are shown in the following table, which based on the "OT Security Detailed Risk Assessment Report". The asset list could refer to "Dummy Project - Inventory Asset List".

The applicable scope of systems, sub-components for this management plan includes:

Location	Asset	Description
03 SCADA Zone	SCADA HMI Server	Graphical monitoring interface
02 Control Zone	IED (Control)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks
01 SIS Zone	IED (Protection)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks
02 Control Zone	Ethernet Switch (Control)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device
01 SIS Zone	Ethernet Switch (Protection)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device
05 Tempory Zone	Wireless AP	A networking hardware device that allows other Wi-Fi devices to connect to a wired network or wireless network

3.0 Definitions

3.1 Definitions

Definition	**Description**
Asset Owner	Individual or organization responsible for one or more Industrial Automation and Control Systems (IACSs).
Automation Solution	Control system and any complementary hardware and software components installed and configured to operate in an IACS.
Component	One of the parts that make up a product or system.
Dependent Component	Component external to the product on which the product depends.
Integration Service Provider	Service provider that provides integration activities for an Automation Solution including design, installation, configuration, testing, commissioning, and handover.
Maintenance Service Provider	Service provider that provides support activities for an Automation Solution after handover.
Product Supplier	Manufacturer of hardware and/or software products.
Recovery Point Objective	Time value that determines the maximum tolerable period of data loss due to a disaster (e.g., data corruption).
Recovery Time Objective	The overall length of time an information system's components or an operation system's components can be in the recovery phase before negatively impacting the organization's mission or mission/business/operating functions.
Service Provider	Individual or organization (internal or external organization, manufacturer, etc.) that provides a specific support service and associated supplies in accordance with an agreement with the asset owner.

3.2 Abbreviations

Abbreviation	**Clarification**
EPC	Engineering, Procurement and Construction
SAT	Site Acceptance Test
SIT	Site Integration Test
VIT	Vulnerability Identification Testing

3.3 Applicable Documents

3.3.1 Employer’s Requirements

No	Employer’s DOC No	DOC Title
1		OT Security Requirements for dummy project
2		Master Time Schedule

3.3.2 Related Documents

No	SESS DOC No	Employer’s DOC No (if applicable)	DOC Title
1			OT Security Management Plan
2			OT Security Vendor Management Plan
3			Dummy Project -Data Flow Diagram
4			Dummy Project - Inventory Asset List
5			Dummy - Simple Network Diagram
6			Dummy Project -Initial Risk Assessment
7			Dummy Project -Detail Risk Assessment

4.0 Project Assets and SuC Description

The System under Consideration (SuC) for IEC 62443-2-4 Dummy System, the applicable scope of systems, sub-components for OT Security Management Plan are shown in the following table, which based on the “OT Security Detailed Risk Assessment Report”. The asset list could refer to “Dummy Project - Inventory Asset List”.

The applicable scope of systems, sub-components for this management plan includes:

Location	Asset	Subcomponents
03 SCADA Zone	SCADA HMI Server	Graphical monitoring interface
02 Control Zone	IED (Control)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks
01 SIS Zone	IED (Protection)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks
02 Control Zone	Ethernet Switch (Control)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device
01 SIS Zone	Ethernet Switch (Protection)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device
05 Tempory Zone	Wireless AP	A networking hardware device that allows other Wi-Fi devices to connect to a wired network or wireless network

5.0 Governance/Strategy

5.1 Main Contractor responsibilities

To ensure compliance with cybersecurity requirements for implementing, managing, and monitoring compliance with OT Security Requirements for dummy projects.

To manage the contractor selection, system implementation, various testing, document delivery, etc. to meet the various security requirements for the Employer.

To supervise the activities of its suppliers to ensure their compliance as described in the vendor’s responsibilities.

To follow the requirement from the Employer:

- The Employer’s security requirements, policies, and procedures
- The Employer’s Management of Change (MOC) and Permit to Work (PtW) processes for changes involving devices, workstations, and servers and connections between them.
- The protection of the confidentiality of the Employer’s data. All the policies, procedures required to protect the confidentiality of the asset owner's data also shall be listed. These requirements shall be implied into the Delegation Contract of subcontractor and/or consultant. The protection of the confidentiality is divided to 4 different categories that data is placed into—depending on its risk and value, include :
  - Public data

    Public data is freely available and does not require any special security measures.

  - Project Internal data

    Internal data is only intended for use within this project, and can include things like the employee handbook, project policies, and certain company-wide communications. Though it should remain private, if this type of information were to be made public, the repercussions would be minimal.

  - Confidential data

    Confidential data must be kept within the project/organization and should only be accessed by authorized personnel. It can include information like pricing details, project system materials, meeting minutes or contact information. If this type of data were to be disclosed, it could damage the project/company or brand.

  - Restricted data

    Restricted data requires the highest level of protection and access must be limited to necessary personnel. Often protected by a Non-Disclosure Agreement (NDA), restricted data can include system design and develop related documents, Various plans and V&V documents, and personally identifiable information (PII), etc.

To supervise and manage the OT security of IEC 62443-2-4 Project in accordance with the requirements of various policies and procedures in the whole life cycle of the project, the responsibilities include:

- Project Management
- Handle project regular meetings
- Review project progress
- Manage the quality of documents
- Submit deliverable documents after the document stage review
- Develop Policies and Procedures Integration Plan
- Assist the Employer in performing the test according to the Inspection and Test Protocol
- Documentation and report of SIT

5.2 Vendors responsibilities

Main vendors include system integrators, product suppliers, and OT-security consultants. System integrators provide engineering and testing services. The vendors and 3rd party shall follow the following requirements:

- Vendor of each system should provide the Security Background Document for each person, who would work for the Dummy project, refer to Appendix.
- All Asset vendors and services directly involved in energy production and transmission processes shall be identified and risk assessments should be performed.
- Relevant acquisition strategies, procedures, and processes shall be utilized to assess, manage, and mitigate the supply chain risks.
- Information security requirements for vendors having access to main system shall be documented.
- Contracts shall be handled by Asset Procurement Processes.
- Before any communication links with external parties are established, it should be ensured that the risks resulting from such system connection is evaluated and that only authorized communication can be exchanged over the link.
- All relevant OT security requirements shall be identified and negotiated with each supplier having access to main systems.
- There shall be an NDA with all suppliers.
- Vendor access should be designed according to risk considerations and security architecture requirements.
- Vendor access shall be kept to a minimum, the required level of access shall be determined individually.
- There shall be an NDA with all suppliers, include to protect of the confidentiality of the PE/O’s data, include but not limit to: documents of contract, technical, specification, meeting minute, sharing documents, etc.
- Vendor access shall be removed after contracts are terminated.
- Vendors having access to Asset assets shall agree to Asset security requirements.

- Vendor must follow Asset Management of Change process for all changes in systems, access or network infrastructure, including changes in service provider, subcontractor, or consultant personnel who have access to Automation Solution.
- Vendor remote connections and file transfers to Asset OT-systems shall follow approved Asset solutions and methods.
- Vendor remote access, especially privileged access shall follow Asset Access Management Rule by using the Least privilege principle for granting access.
- Vendor access shall be monitored or otherwise logged.
- Vendor shall ensure that OT services are documented in an operating procedure to ensure effective and uniform operation of the services provided to Asset.
- Vendor shall without delay report identified or suspected breaches or cyber incidents, including security incidents related to remote access, to Asset.
- The supplier service deliveries shall regularly be monitored, reviewed, and audited.
- All remote access connections through the network must be documented and reviewed at least annually. This should include the applications used for remote access.
- Vendor remote connections and file transfers to Asset Owner’s OT-systems shall follow Asset Owner’s solutions and methods. Remote access should be approved by Asset Owner and then is executed by vendor. Template for approval about remote access connection is shown in the below.
- Vendor remote access, especially privileged access, shall follow Asset Owner’s Access Management Rule by using the Least privilege principle for granting access.
- Vendor should provide security-related background checks of the personnel for dummy project ensure them have successfully passed security-related background checks.
- Vendor should protect the confidentiality of the Employer’s data.

Remote Access Connection Application			
Purpose			
Access Method	System or device: Account: such as Engineer, viewer Source: IP Address Protocol or software: Multi-factor Authentication:		
Duration of Access	Start: Date and Time End: Date and Time		
Applicant	Team:	Company:	Name:
	Job Title	Email	Phone
Approve	Target Department	Job Title	Name: Sign with date
	IT/OT Operating Team	Job Title	Name: Sign with date

The responsibilities of OT-security Consultant include:

- OT security consultant and documentation guidance for ICP and Vendors
- Develop Policy and Procedures
- Develop OT Security Management Plan
- Develop Vendor Management Plan
- Develop Awareness Material
- Perform Initial Level Risk Assessment with employer and system integrators
- Verify and report the Gate 1: IEC 62443-2-4 organizational controls self-assessment
- Perform Detailed Risk Assessment with employer and system integrators
- Report the Risk Mitigation Plan
- Develop OT-Security Inspection and Test Protocol plan document for OT-security only
  - Inspection test plan and log form
  - Test scenarios aligned with the cybersecurity requirements of the project
  - FAT/SAT/SIT checklist procedures -Provided by subcontractor/SI/Suppliers for OT-security Consultant of Contractor to review and check
  - Inspection procedure for the evaluation of the SuC capabilities to meet the identified SLs
- Update requirements and security solutions for OT-Security Policy and Procedure Design Practices
  - Vendor Management policy
  - Account Management policy
  - Vulnerability Management procedure
  - Backup/Restore procedure - Provided by subcontractor/SI/Suppliers for OT-security Consultant of Contractor to review and check
  - Systems Malware Protection procedure
  - Change and Patch Management procedure
  - Logging, monitoring, and reporting procedure
- Support the development of an Integration Plan for OT-Security Policy and Procedure Design Practices
- Verify and report the Gate 2: IEC 62443-2-4 organizational controls self-assessment
- Perform and verify the security solutions for executing controls including:
  - User accounts management system or join domain control
  - Anti-malware system
  - On-site automated Asset Management Software (AMS)
  - Backup/restore
  - Security monitoring and log collection or SIEM log collector for the OT System
  - Vulnerability scanning
  - Penetration testing
  - Firewall, if need
  - Intrusion Detection. System (IDS), if need

- Planning and Reviewing the FAT Inspection and Test Protocol (ITP) procedures (OT-security only)
- Verification and Review of the Performing of the FAT test
- Aggregation and Reporting – Documentation of the FAT test
- Planning and Reviewing the SAT Inspection and Test Protocol (ITP) procedures (OT-security only)
- Verification and Review of the Performance of the SAT test
- Aggregation and Reporting – Documentation of the SAT
- Planning and Reviewing the SIT Inspection and Test Protocol (ITP) procedures (OT-security only)
- Consultant for the Employer to perform the SIT test
- Consultant for the Gate 3 Review - Compilation of all OT-security related documents
- Perform Training Package

The responsibilities of system integrators include:

- Develop a Preliminary Asset List
- Develop a Simple Network Diagram
- Cooperate with OT-security Consultant to perform the Initial Level Risk Assessment
- Support Gate 1: IEC 62443-2-4 organizational controls self-assessment
- Develop Asset List
- Develop OT-Security Control System and Network Architecture
- Perform Hardening Concepts and Practices
- Cooperate with OT-security Consultant to perform the Detailed Risk Assessment
- Support Risk Mitigation Plan
- Support the development of the Inspection and Test Protocol (OT-Security only)
- Support OT-Security Policy and Procedure Design Practices
- Support Gate 2: IEC 62443-2-4 organizational controls self-assessment
- Implement security control & countermeasures to system and assets, including security solutions (Like Setting username & password, installing Antivirus), security procedure documents (e.g. account management, Vulnerability Management, backup/restore…), function requirements (IEC 62443-3-3, etc.)
- Support for installing, testing, and verifying security solutions for executing controls with OT-security Consultant.
- Develop the FAT Inspection and Test Protocol (ITP) test cases (OT-security only), and perform the tests and test reports (Some OT-Security tests could be performed by OT-security Consultant, if available)
- Support the OT-Security FAT test report
- Develop the SAT Inspection and Test Protocol (ITP) test cases (OT-security only), and perform the tests and test reports (Some OT-Security tests could be performed by OT-security Consultant, if available)
- Join and support the SAT test as documented in the Inspection and test protocol
- Support the OT-Security SAT test report

- Support the Employer to perform the SIT test

The responsibilities of product suppliers include:

- Support for tasks of OT Security Detail Design
- Support for tasks of FAT TEST
- Support for tasks of SAT TEST
- Support for tasks of SIT TEST (in case if necessary)

5.3 Asset responsibilities

- Set the project requirements (including cybersecurity requirements)
- Provide final approval on cybersecurity assessments, reviews, and decisions in accordance with requirements documented in OT Security Requirements for dummy project for
- Accept the project deliverables.

After the takeover, will be responsible for the cybersecurity of all systems.

6.0 Communicate Requirements to Vendor

Vendor must be able to meet OT security requirements. Therefore, ICP integrates the OT security process at every stage of supplier selection.

6.1 Vendor selection process

- Consideration of the rationale of the vendor's proposal. The proposal should include the requirements from Security Management and this Security Vendor Management Plan in order to include it in the evaluation. The requirements from management plans and Asset owner will list in the Delegation Contract to follow.
- Provide security recommendations based on risk on the existing SuC.
- Cybersecurity Clauses are included in the control system.

6.2 Engineering plan

ICP will perform the following tasks to ensure compliance with the cybersecurity design.

- Specifying cybersecurity requirements for this project
- Check the technical specifications for related systems with control systems to meet the requirements of cybersecurity.
- SESS will provide technical support at kick of meeting (KOM) to explain and clarify the cybersecurity design related to ICP specifications.
- Checking and Validating vendor documentation from the point of view during project lifecycle stages.
- Held the period meeting to review the project progress, and audit that the sub-vendors follow Asset's policies and processes.
- Checking delivery of cybersecurity policies and procedures during project lifecycle stages.

7.0 Vendor Management after Purchase Order

7.1 Progress Follow-up

Hold meetings from time to time to meet requirements:

- To check progress on time, on step in the preparation.
- To discuss all issues and clarify the problem to solve.
- To audit the progress of project by the regular meeting.

7.2 Vendor Tests Management

7.2.1 Inspection and Test Protocol (ITP)

OT-security Consultant will provide a documented procedure to examine IACS and processes of the SuC and provide evidence of their conformity with cybersecurity requirements, including but not limited to:

- Inspection test plan and log form
- Test scenarios aligned with the cybersecurity requirements of the project
- FAT/SAT/SIT checklist procedures
- Inspection procedure for the evaluation of the SuC capabilities to meet the identified SLs

ICP will provide a Policies and Procedures Integration Plan with the definition of all technical solutions. The ITP and Policies and Procedures Integration testing, verification, and validation would be performed in FAT and SAT stages.

7.2.2 FAT

System integrators and OT-security Consultants will perform inspections and tests (including the conformity of Vendors OT Security Rule Baseline) on vendor premises before the delivery on-site to check the System under Consideration. FAT may be witnessed by Asset. Inspection AND Test protocol procedures dedicated to cybersecurity related to FAT will be used.

To identify any problems or issues with the SuC before they are delivered. Including but not limited to:

- Planning and Reviewing the FAT ITP -Inspection and Test Protocol (ITP) procedures (OT-security only) by OT-security Consultant.

- Perform the FAT ITP test by system integrators, including test cases, testing, and test reports.

- Perform the integration test for OT-Security Policy and Procedure Design Practices by system integrators or OT-security Consultants, include test cases, testing, and test reports (if applicable).

- Verification and Review of the performing of the FAT test by OT-security Consultant.

- Aggregation and Reporting of the FAT test by OT-security Consultant.

7.2.3 SAT

Overall testing of the vendor deliveries to validate if they follow the OT security requirements of Inspection and Test Protocol (ITP) procedures dedicated to the SAT test.

The Site Acceptance checks if the SuC is deployed in its working environment in accordance with Employer cybersecurity requirements. Including but not limited to:

- Planning and Reviewing the SAT Inspection and Test Protocol (ITP) procedures (OT-security only) by OT-security Consultant.

- Perform the SAT ITP test by system integrators, including test cases, testing, and test reports.

- Perform the integration test for OT-Security Policy and Procedure Design Practices by system integrators or OT-security Consultants, including test cases, testing and test reports.

- Verification and Review of the performance of the SAT test by OT-security Consultant.

- Aggregation and Reporting of the SAT test by OT-security Consultant.

8.0 Appendix Template of Security Background Document

The content of Security Background Document Template is described as follows:

Background Checklist

Employee Name: [employee name]
Conductor: [your name]
Company Name: [your company name]

The following checklist is specifically designed to validate pertinent details about a potential candidate's personal, professional, and legal history during the hiring process. Follow the guideline and ensure to check every box after verifying each particular information:

I. Education Verification:

Have educational qualifications been verified through official transcripts or certificates?

- ☐ yes
- ☐ no

II. Employment History:

Have previous employment records been verified, including dates of employment and job titles?

- ☐ yes
- ☐ no

III. Criminal Record Check:

Has a comprehensive criminal background check been conducted?

- ☐ yes
- ☐ no

IV. Reference Checks:

Have references provided by the candidate been contacted and verified?

- ☐ yes
- ☐ no

V. Professional License Verification:

Have any professional licenses or certifications claimed by the candidate been verified?

- ☐ yes
- ☐ no

VI. Credit History Check:

Is there a need for a credit history check, especially for roles involving financial responsibilities?

- ☐ yes
- ☐ no

VII. Drug Screening:

Has the candidate undergone drug screening as per company policy and legal requirements?

- ☐ yes
- ☐ no

VIII. Identity Verification:

Has the candidate's identity been verified through government-issued documents?

- ☐ yes
- ☐ no

IX. Social Media Screening:

Has social media screening been conducted to assess any potential red flags?

- ☐ yes
- ☐ no

X. Global Watchlist Check:

Have checks been made against global watchlists for any security concerns?

- ☐ yes
- ☐ no

XI. Motor Vehicle Record Check:

Is a motor vehicle record check necessary for roles involving driving responsibilities?

- ☐ yes
- ☐ no

XII. International Background Checks:

For international candidates, have appropriate background checks been conducted in their home countries?

☐ yes
☐ no

XIII. Compliance with Legal Requirements:

Have all background checks been conducted in compliance with relevant laws and regulations?

☐ yes
☐ no

XIV. Document Retention:

Are all verification documents securely retained as per legal requirements?

☐ yes
☐ no

XV.Final Review:

Has a final review of all background verification results been conducted before making a hiring decision?

☐ yes
☐ no

XVI. Some government project background checks

If the outsourced manufacturer's entrusted business involves information and communication software, hardware or services, the Nationality of team members cannot be People's Republic of China (PRC).

☐ yes
☐ no ： Note :_____

Those who have committed the crime of leaking secrets, civil strife, or foreign aggression, and have been sentenced, or there are wanted cases that have not yet been concluded.

☐ yes
☐ no ： Note :_____

Former civil servants who were punished or given an administrative penalty of demerit or above for violating relevant security and confidentiality regulations.

☐ yes
☐ no ： Note :_____

Have been induced or coerced by foreign governments, mainland China, Hong Kong or Macau governments to engage in matters detrimental to national security or major interests.

☐ yes
☐ no ： Note :_____

Other specific items related to the protection of state secrets contained in the bidding announcement, bidding documents or contract.

☐ yes
☐ no ： Note :_____

<<Text End>